

Autor: Exxeta, Daniel Schäfer

Veröffentlicht unter:

<https://exxeta.com/blog/dora-eu-leitfaden-fuer-die-staerkung-der-digitalen-widerstandsfahigkeit>

DORA: Stärkung der digitalen Widerstandsfähigkeit von Finanzunternehmen

Die Stabilität und Sicherheit der europäischen Finanzinfrastruktur in der digitalen Ära zu gewährleisten, ist eine der zentralen Herausforderungen von Finanzinstituten. Mit dem *Digital Operational Resilience Act* (DORA) setzt die Europäische Union ein Rahmenwerk, welches sich genau dieser Aufgabe annimmt. Nun sind europäische Finanzunternehmen gefragt, diese bis Anfang 2025 umzusetzen. In diesem Artikel bieten wir einen umfassenden Überblick über DORA und seine Bedeutung für Finanzinstitute.

Hintergrund und Notwendigkeit

Mit dem rasanten Anstieg digitaler Dienste und der zunehmenden Vernetzung der Welt erleben wir eine beispiellose digitale Transformation. Diese Änderungen bringen jedoch auch neue Herausforderungen mit sich, insbesondere in Bezug auf Cybersicherheit und operativer Widerstandsfähigkeit. In diesem Zusammenhang ist der Digital Operational Resilience Act (DORA), eine Verordnung der EU, von entscheidender und wegweisender Bedeutung.

Die digitale Landschaft verändert sich ständig und rasch. Mit der zunehmenden Abhängigkeit von digitalen Technologien und Dienstleistungen hat sich das Risiko digitaler Störungen und Angriffe vervielfacht. In diesem Kontext ist ein EU-weit harmonisierter regulatorischer Rahmen wie die DORA notwendig geworden, der Finanzinstitute dazu verpflichtet, geeignete Maßnahmen zum Schutz gegen digitale Bedrohungen zu treffen und ihre operative Resilienz zu stärken.

Konsultationsphase für RTS und ITS läuft bereits



Finale RTS/ITS erscheinen erst im Laufe des Jahres 2024.

Ziele und Merkmale der DORA

Der Hauptzweck von DORA ist die Gewährleistung der Stabilität und Sicherheit der europäischen Finanzinfrastruktur in der digitalen Ära. Die EU-Verordnung zielt darauf ab, EU-weit einheitliche und strengere Vorschriften in Bezug auf Cybersicherheit, Informationssicherheit, Betriebskontinuität und Risikomanagement innerhalb der Finanzbranche zu etablieren.

Die Bestimmungen von DORA beinhalten eine Reihe von Vorschriften und Verpflichtungen, die sich auf verschiedene Handlungsfelder der Finanzdienstleister erstrecken, darunter:

IKT-Risikomanagement: Finanzinstitute müssen ein robustes Management für Informations- und Kommunikationstechnologie (IKT)-Risiken einführen, verbessern und aufrechterhalten. Dazu gehören Strategien, Richtlinien und Verfahren zur Identifizierung, Klassifizierung, Bewertung, Überwachung und Minderung von IKT-Risiken. Ferner ist eine unabhängige IKT-Risikokontrollfunktion für das Management und die Überwachung des IKT-Risikos einzuführen.

Incident Reporting: Im Falle von erheblichen IKT-bezogenen Vorfällen ist eine schnelle und umfassende Meldung erforderlich. Die Verordnung legt genaue Anforderungen und Fristen für solche Berichte fest.

Digital Resilience Testing: DORA schreibt weiter vor, dass Finanzinstitute regelmäßige erweiterte Penetrationstests (Threat-Led-Penetration-Test, kurz TLPT) zur digitalen Widerstandsfähigkeit durchführen müssen, um potenzielle Schwachstellen zu identifizieren und Gegenmaßnahmen zu erarbeiten. Als Grundlage hierfür dient das Tiber-EU-Rahmenwerk. Ebenso definiert die DORA die Anforderungen an die Tester, die diese Penetrationstests durchführen.

Management von IKT-Drittanbieterrisiken: Unter DORA müssen Finanzinstitute eine effektive Überwachung und Kontrolle von IKT-Drittanbietern sicherstellen, einschließlich Cloud-Service-Anbietern. Zu beachten gilt, dass der Empfängerkreis der IKT-Drittanbieter sehr weit gefasst ist.

Auswirkungen der DORA

DORA hat tiefgreifende Auswirkungen auf die Geschäftspraktiken und das Risikomanagement von Finanzdienstleistern. Diese Verordnung wird Institute dazu drängen, ihre aktuellen Sicherheits- und Resilienzstrategien sehr rasch zu prüfen und entsprechend anzupassen bzw. zu erweitern. DORA bietet für Institute darüber hinaus jedoch auch die Chance, nicht nur ihre eigene operative Widerstandsfähigkeit zu stärken und Risiken für sich selbst angemessen zu reduzieren, sondern auch das Vertrauen ihrer Kunden und Partner in ihre digitalen Dienstleistungen zu erhöhen.

Erläuterungen von RTS und ITS unter DORA

Ein weiterer wichtiger Aspekt von DORA ist die Einführung der Implementierung von technischen Regulierungs- (RTS) und Durchführungsstandards (ITS). Diese Standards konkretisieren als detaillierter Leitfaden die Anforderungen der DORA und sollen einen einheitlichen europaweiten Implementierungsstandard sicherstellen.

Technische Regulierungsstandards (RTS)

RTS sind bindende technische Standards, die jedoch einen stärkeren Fokus auf den regulatorischen Aspekten haben. RTS, die unter DORA erstellt werden, enthalten detaillierte Vorgaben zur Anwendung der DORA-Anforderungen, u.a. in Bezug auf die Handlungsfelder Cybersicherheit, operative Widerstandsfähigkeit und IKT-Drittanbietermanagement.

Technische Durchführungsstandards (ITS)

ITS sind ebenfalls bindende technische Standards, die von den zuständigen Aufsichtsbehörden erstellt werden, um die praktische Anwendung der regulatorischen Vorschriften zu erleichtern. Unter DORA enthalten die ITS spezifische Anforderungen an Aspekte wie u.a. die IKT-Risikomanagement-Prozesse, die Durchführung von digitalen Belastungstests und die Meldepflichten für IKT-bezogene Vorfälle.

Die Bedeutung von ITS und RTS

Die RTS und ITS unter DORA spielen eine entscheidende Rolle bei der Auslegung und Umsetzung der Verordnungsvorgaben. Sie stellen eine konkrete und detaillierte Anleitung bereit, die den betroffenen Organisationen hilft, ihre IKT-Prozesse und -Systeme in Einklang mit den Anforderungen von DORA zu bringen und somit eine Compliance zu gewährleisten. Es ist wichtig, dass Institute die relevanten RTS und ITS frühzeitig im Fokus haben und deren Änderungen sehr detailliert beobachten und in ihre Implementierungsstrategien berücksichtigen und einbeziehen.

Insgesamt tragen die RTS und ITS dazu bei, ein hohes Niveau an digitaler Widerstandsfähigkeit zu erreichen und dauerhaft aufrechtzuerhalten. Sie unterstützen sowohl die Finanzinstitute selbst als auch die Aufsichtsbehörden dabei, ihre jeweiligen Rollen im Rahmen von DORA effektiv wahrzunehmen. Diese Standards werden sorgfältig entwickelt und kontinuierlich aktualisiert, um den sich ständig weiterentwickelnden IKT-Risiken Rechnung zu tragen.

DORA Handlungsfelder



Die BaFin-Rundschreiben und die neue DORA-Verordnung

Die jüngst erlassene DORA-Verordnung wirkt sich auf eine umfangreiche Gruppe von Finanzinstituten aus, darunter Banken, Versicherungsunternehmen, Kapitalverwaltungsgesellschaften und Anbieter elektronischer Zahlungssysteme, die bereits unter der Aufsicht der BaFin stehen. Vor dem Hintergrund der strikten IT- und Cybersicherheitsvorschriften, die in Deutschland bereits durch mehrere BaFin-Rundschreiben (BAIT, VAIT, ZAIT, KAIT, MaRisk) konkretisiert wurden, verfügen viele dieser Organisationen bereits jetzt schon über eine robuste Infrastruktur. Insbesondere nimmt die im Jahre 2021 novellierte BAIT bereits viele Elemente der DORA vorweg.

Zusätzlich zu den bereits regulierten Finanzunternehmen erweitert, wie oben erwähnt, die DORA-Verordnung in Art. 2 den Kreis der Verpflichteten erheblich, so z.B. um Buchhaltungsdienstleistern, Kreditrating-Agenturen, Bonitätsprüfern und Crowdfunding-Plattformen. Des Weiteren fallen unter die Verordnung auch Anbieter von Informations- und Kommunikationstechnologien (IKT), wenn sie eine marktbeherrschende Stellung in einem der aufgeführten Bereiche haben. Hierbei handelt es sich um eine breite Palette von Akteuren, von Entwicklern von Banking-Apps über Hersteller von Geldautomaten und Betreiber von Kernbankensystemen bis hin zu Cloud-Diensten und Rechenzentren.

Daher ist es für zahlreiche Unternehmen, die bisher nicht unter der Aufsicht der BaFin standen, dringend ratsam sehr zeitnah zu überprüfen, ob sie den neuen Anforderungen der DORA unterliegen und ob sie entsprechende Maßnahmen ergreifen müssen.

Finale Entwürfe der ESAs zur ersten Batch Serie von DORA RTS und ITS

Der 17. Januar 2024 stellt ein wichtiges Datum im Rahmen der Implementierung der DORA-Anforderungen dar. Durch das erste Paket von endgültigen Entwürfen technischer Standards durch die europäischen Regulierungsbehörden (EBA, EIOPA und ESMA – bekannt als die ESAs) werden wesentliche Anforderungen der DORA konkretisiert. Die finalen Entwürfe wurden nun zur Bewertung und Zustimmung an die Europäische Kommission gesendet, die die endgültigen RTS und ITS im EU-Amtsblatt veröffentlichen wird.

Kurzüberblick der Inhalte des finalen 1st Batch:

RTS und ITS über den IKT-Risikomanagementrahmen und einen vereinfachten

Ansatz: Diese legen fest, wie Finanzinstitute ein wirksames Management für IKT-Risiken einrichten und beibehalten sollen. Die Implementierung eines vereinfachten Rahmens soll kleineren Einrichtungen einen für sie angepassten Weg mit gewissen Erleichterungen ermöglichen.

RTS für die Einstufung von IKT-bezogenen Vorfällen: Diese definieren Kriterien für Vorfälle, die als signifikant gelten, um eine einheitliche Behandlung und Berichterstattung über die verschiedenen Sektoren hinweg zu gewährleisten.

RTS zur Spezifikation der Leitlinie über IKT-Dienste, die kritische oder wichtige

Funktionen unterstützen und von IKT-Drittanbietern erbracht werden: Im Fokus steht hierbei das Management der von IKT-Drittanbietern bereitgestellten Dienste, so dass Finanzinstitute eine angemessene Prüfung und Überwachung solcher Dienste sicherstellen.

ITS zur Erstellung von Standardvorlagen für das Informationsregister: Diese definieren und erweitern die aktuellen Anforderungen und benötigten Informationen für das Erstellen und Führen eines Registers aller IKT-Servicevereinbarungen mit Drittanbietern, was zu einer besseren Transparenz und Überwachung führen soll.

EU beginnt öffentliche Konsultation für den 2nd Batch von DORA RTS, ITS und

Leitlinien Mit der Herausgabe des zweiten Batchs von DORA RTS, ITS und Leitlinien, die bis zum 04. März 2024 zur öffentlichen Konsultation stehen, beschreitet die EU neue Wege, um die digitale Beständigkeit des Finanzsektors weiter zu stärken. Die neuen RTS, ITS und Leitlinien führen detaillierte Vorschriften für die effektive Bewältigung von IKT-Risiken, die Berichterstattung und Einstufung von IKT-bezogenen Vorfällen, Belastbarkeitstests sowie dem Management von Risiken durch Drittanbieter ein.

Kurzüberblick der Kernpunkte des 2nd Batch:

RTS und ITS zur Detaillierung der Anforderungen an das Incident Reporting: Definiert werden spezifische Anforderungen und Fristen für die Berichterstattung über signifikante IKT-bezogene Vorfälle, um eine schnelle Reaktionszeit sicherzustellen.

RTS zur Einführung von Resilienz Tests: Die Pflicht zur Durchführung von Threat-Led Penetrationstests (TLPT), um mögliche Schwachstellen zu identifizieren und zu sichern.

RTS zur Spezifizierung von Elementen bei der Untervergabe von kritischen oder wichtigen Funktionen: Konkretisierung der Anforderungen, die Finanzinstitute bei der Untervergabe von kritischen oder wichtigen IKT-Dienstleistungen berücksichtigen müssen.

RTS und Leitlinien zur Förderung der Kooperation und Harmonisierung der

Aufsicht: RTS und Leitlinien für eine engere Zusammenarbeit zwischen den europäischen Regulierungsbehörden (ESAs) und den nationalen Behörden zielen auf eine konsistente und effektive Überwachung sowie Harmonisierung der Aufsichtspraktiken im Hinblick auf kritische IKT-Drittanbieter ab.

Leitlinien für die Schätzung der aggregierten Kosten und Verluste, die durch schwerwiegende IKT-bezogene Vorfälle verursacht werden: Finanzinstitute müssen der zuständigen Aufsichtsbehörde auf Anfrage die geschätzten aggregierten jährlichen Kosten und Verluste melden, die durch schwerwiegende IKT-bezogene Vorfälle verursacht wurden.

Nächste Schritte für Finanzinstitute im Hinblick auf den 1st und 2nd Batch der RTS, ITS und Leitlinien

Die Veröffentlichung des 1st Batch der finalen Entwürfe technischer Standards unter DORA und die Einleitung der öffentlichen Konsultation für den 2nd Batch setzen neue Standards im Umgang mit digitalen Risiken im Finanzsektor. Finanzinstitute sind nun gefordert, diese dynamische regulatorische Umgebung sehr genau zu beobachten und zu analysieren und im Rahmen ihrer Implementierungsstrategien zu berücksichtigen. Entscheidenden Schritte für Finanzinstitute, um den Anforderungen des 1st und 2nd Batch gerecht zu werden sind u.a.:

1. Umfassende Gap-Analyse:

Finanzinstitute sollten – wenn nicht bereits geschehen – umgehend mit einer umfassenden Gap-Analyse beginnen oder ihre bestehenden Analysen überprüfen und aktualisieren, um schnellstmöglich ihren eigenen regulatorischen Reifegrad zu bestimmen. Dies umfasst die Bewertung bestehender IKT-Risikomanagement Rahmenwerke und Praktiken, Incident Reporting-Verfahren, Resilienz Tests, das Management von Risiken von IKT-Drittanbietern sowie das entsprechende Vertragsmanagement.

2. Integration der Änderungen aus dem 1st Batch:

Ein besonderes Augenmerk sollte auf den wesentlichen Änderungen liegen, die im ersten Paket der endgültigen Entwürfe vorgenommen wurden. Die Anpassungen, die auf das Feedback aus der Konsultationsphase resultieren, sollten sorgfältig geprüft und in die Implementierungspläne der Institute integriert werden.

3. Aktive Teilnahme an der öffentlichen Konsultation:

Finanzinstitute sollten die Möglichkeit nutzen (auch mittels ihrer Verbände), aktiv an der öffentlichen Konsultation des 2nd Batchs teilzunehmen. Dies bietet eine Plattform, um Bedenken vorzutragen und Vorschläge zu machen. Unter anderem ist hier anzuraten eine Verlängerung der Implementierungsfristen vorzuschlagen und die Inhalte noch einmal sehr genau auf Ihre praktische Durchführbarkeit prüfen zu lassen.

4. Entwicklung und Testen von Resilienz Strategien:

Die Einführung von Resilienz Tests, einschließlich des Threat-Led Penetration Testing (TLPT), erfordert, dass Finanzinstitute ihre Strategien zur Identifizierung und Absicherung potenzieller Schwachstellen entwickeln und testen. Hier bietet sich die Prüfung des Tiber-EU Rahmenwerkes an. Ebenfalls sollte es nicht unterschätzt werden frühzeitig entsprechende Ressourcen aufzubauen bzw. Ressourcen für solche Penetrationstests zu finden.

5. Verstärkung des Managements von Drittanbierrisiken:

Angesichts der detaillierten Vorgaben für das Risikomanagement im Hinblick auf IKT-Drittanbieter sollten Finanzinstitute ihre Überwachungs- und Kontrollmechanismen dieser Anbieter überprüfen und verstärken. Bereits jetzt ist es ratsam sich mit den IKT-Drittanbietern bzgl. der Anpassungen des Vertragswesens auszutauschen.

Fazit und Ausblick

Der Digital Operational Resilience Act (DORA) ist ein entscheidender Schritt in Richtung eines widerstandsfähigeren und sichereren digitalen Finanzmarkts. Die neuen Vorgaben ermöglichen Unternehmen ihre Cybersicherheit und operative Widerstandsfähigkeit zu stärken und so das Vertrauen von Kunden und Partnern zu gewinnen. Trotz der Herausforderungen, die ihre Umsetzung mit sich bringt, bieten die neuen Anforderungen den relevanten Instituten die Möglichkeit, ihre Wettbewerbsfähigkeit in der digitalen Wirtschaft zu stärken und sich gleichzeitig zukunftsfähig aufzustellen. Für Institute, die in den Anwendungsbereich der DORA fallen, ist es aufgrund der kurzen Umsetzungsfrist bis zum 17. Januar 2025 dringend geboten – falls noch nicht geschehen – zeitnah die entsprechende DORA Gap-Analyse zu starten, um die fristgerechte Implementierung der DORA-Anforderungen sicherzustellen.